

LAPORAN AUDIT KEAMANAN APLIKASI

SIPAT TERPADU (E-RANDIS · E-LABEL · SIPAT)

Sasaran audit	Aplikasi SIPAT Terpadu — https://terpadu.sipat-donggala.my.id
Lokasi kode	<code>/home/arif/Projek/SIPAT_Terpadu</code>
Teknologi	Laravel 12.67 · PHP 8.3 · MySQL · Blade + Bootstrap
Tanggal pelaksanaan	24 September 2026
Jenis audit	Uji keamanan aplikasi web (grey-box: review kode sumber + uji HTTP non-destruktif)
Klasifikasi dokumen	TERBATAS — mengandung detail celah yang belum diperbaiki
Jumlah temuan	14 (4 Kritis · 4 Tinggi · 5 Sedang · 1 Rendah)
Status	BELUM AMAN — 4 temuan kritis dapat dieksploitasi dari internet

1. Ringkasan Eksekutif

Aplikasi SIPAT Terpadu mengelola data Barang Milik Daerah berupa arsip BPKB kendaraan dinas, sertifikat tanah, dan dokumen penyerahan aset. Audit ini menemukan **empat celah berkategori kritis yang seluruhnya dapat diakses dari internet tanpa kredensial apa pun atau dengan kredensial yang mudah diperoleh**.

Tiga hal terpenting:

- Seluruh arsip dokumen dapat diunduh siapa saja.** 718 berkas BPKB dan sertifikat ($\pm 1,2$ GB) tersimpan pada direktori yang dilayani langsung oleh web server. Penulis memverifikasi dua berkas nyata terunduh dari internet dengan status HTTP 200, **tanpa login**. Nama berkas berpola dan dapat diprediksi sehingga penyerang dapat menyusun daftar URL secara otomatis. Dokumen ini memuat nama pemegang, alamat, NIK, nomor rangka, dan nomor mesin kendaraan.
- Kontrol akses modul arsip (e-LABEL) hanya memeriksa status login, bukan peran pengguna.** 65 endpoint yang bersifat mengubah data — termasuk menghapus catatan BPKB, menyetujui peminjaman arsip, dan mengubah pengaturan situs — dapat dijalankan oleh pengguna mana pun yang berhasil login. Pemisahan data per-OPD juga tidak diterapkan pada modul ini, sehingga satu akun OPD dapat membaca arsip OPD lain.
- Registrasi akun terbuka untuk publik di server produksi.** Siapa pun dapat membuat akun pada halaman `/register` dan langsung memperoleh akses ke aplikasi

internal. Temuan ini menggandakan dampak temuan nomor 2. Ditambah kenyataan bahwa kata sandi akun superadmin masih bernilai bawaan (`admin123`, terverifikasi dari hash pada dump basis data) dan halaman login tidak memiliki pembatas percobaan, jalur menuju pengambilalihan penuh aplikasi bersifat langsung.

Perhatian terhadap audit sebelumnya. Dokumen `audit.md` tertanggal 22 Agustus 2026 menyatakan "*SEMUA TEMUAN BERHASIL DIPERBAIKI (RESOLVED / COMPLIANT)*". Kesimpulan tersebut tidak dapat dipertahankan. Audit lama hanya memeriksa **keberadaan** middleware `auth` pada controller, dan tidak menguji hal-hal yang menentukan pada sistem ini: otorisasi per-peran, pemisahan data antar-OPD, paparan berkas pada direktori publik, jalur registrasi, serta pengelolaan kredensial. Seluruh temuan dalam laporan ini berada pada ranah yang tidak tercakup audit lama.

Kesimpulan. Aplikasi belum layak dinyatakan aman. Empat temuan kritis perlu ditutup sebelum laporan ini disebarakan lebih lanjut, dan asumsi harus diambil bahwa seluruh dokumen arsip yang pernah dapat diakses publik telah bocor.

2. Ruang Lingkup dan Metodologi

Termasuk dalam lingkup (in-scope):

- Seluruh route aplikasi (384 route terdaftar) beserta middleware efektifnya.
- Controller, Form Request, Model, Service, dan konfigurasi middleware.
- Konfigurasi penyimpanan berkas (disk `public` vs `local`), symlink `public/storage`.
- Dependensi PHP (`composer audit`) dan riwayat Git untuk kebocoran kredensial.
- Uji HTTP langsung ke server produksi: **hanya metode GET/HEAD**, non-destruktif, pada 9 URL; tidak ada upaya autentikasi, tidak ada pembuatan akun, tidak ada pengunggahan berkas, dan tidak ada pengujian yang mengubah data.

Di luar lingkup (out-of-scope):

- Pengujian penetrasi terhadap server web/OS, jaringan, dan basis data secara langsung.
- Aplikasi SSO pada `auth.sipat-donggala.my.id` (hanya diperiksa dari sisi SIPAT Terpadu).
- Pengujian beban, failover, dan pemulihan bencana.
- Audit kepatuhan formal (UU PDP / ISO 27001) — hanya catatan keterkaitan.

Metode:

1. Pemetaan route dan middleware efektif (`php artisan route:list --json`).
2. Analisis statis: pencarian pola berisiko (raw SQL, mass assignment, `{!! !!}`, `exec`, validasi unggahan, hardcoded secret).
3. Verifikasi terarah terhadap bukti yang dapat diamati (HTTP status, isi berkas, hash).
4. Verifikasi kredensial bawaan secara **offline** terhadap hash pada dump basis data.

Asumsi dan keterbatasan:

- Uji HTTP dilakukan dari luar tanpa kredensial, sehingga dampak akhir bagi pengguna ber-role tertentu sebagian disimpulkan dari pembacaan kode.
- Bukti temuan kritis nomor 2 dan 3 (rantai registrasi → akses modul arsip) dinyatakan **terverifikasi secara kode**; pembuktian dengan akun uji pada server produksi belum dilakukan karena memerlukan izin tertulis pemilik sistem.
- Dump basis data yang dianalisis bertanggal 16 September 2026; status kredensial perlu dikonfirmasi ulang oleh pemilik sistem.

3. Profil Permukaan Serangan

Dari 384 route yang terdaftar, sebaran proteksi efektifnya:

Middleware efektif	Jumlah route	Keterangan
<code>web</code> , <code>auth</code>	167	Hanya butuh login — termasuk seluruh modul e-LABEL
<code>web</code> , <code>auth</code> , <code>role:superadmin,admin</code>	94	Sudah benar
<code>web</code> (tanpa autentikasi)	29	Portal publik, health check, alias pencarian
<code>web</code> , <code>auth</code> , <code>role:superadmin</code>	26	Sudah benar
<code>web</code> , <code>guest</code>	4	Login, register, lupa sandi
Tanpa middleware	3	Rute internal penyajian berkas sementara

Dua hal yang langsung terlihat dari tabel ini: (a) kelompok terbesar route terproteksi hanya memerlukan status login, dan (b) **65 dari 167 route tersebut adalah endpoint yang mengubah data** (POST/PUT/DELETE), tanpa pemeriksaan peran.

4. Klasifikasi Tingkat Risiko

Tingkat	Kriteria yang dipakai dalam laporan ini
KRITIS	Dapat dieksploitasi dari internet tanpa kredensial, atau memberi dampak langsung pada kerahasiaan/integritas data pribadi dalam skala besar, atau berujung pada pengambilalihan aplikasi. Wajib ditangani ≤ 24 jam.
TINGGI	Dapat dieksploitasi oleh pengguna berakun (termasuk akun yang dapat dibuat sendiri), atau merusak integritas data/kepercayaan publik. Tangani ≤ 1 minggu.
SEDANG	Memerlukan prasyarat tertentu, namun menaikkan risiko secara nyata bila digabungkan dengan temuan lain. Tangani ≤ 1 bulan.
RENDAH	Praktik yang menyimpang dari kaidah keamanan; belum dieksploitasi secara langsung pada kondisi saat ini.

Referensi yang dipakai untuk kategorisasi: OWASP Top 10 (2021), CWE, serta relevansi terhadap UU No. 27 Tahun 2022 tentang Pelindungan Data Pribadi.

5. Daftar Temuan

ID	Temuan	Tingkat	Kategori OWASP	Bukti
K-01	Arsip BPKB & sertifikat dapat diunduh tanpa autentikasi	KRITIS	A01 Broken Access Control · CWE-284, CWE-548	Terverifikasi dari internet
K-02	Registrasi akun terbuka untuk publik di produksi	KRITIS	A01 · CWE-287, CWE-1188	Terverifikasi dari internet
K-03	Modul e-LABEL tanpa pemeriksaan peran & tanpa pemisahan OPD	KRITIS	A01 · CWE-862, CWE-639	Terverifikasi dari kode
K-04	Kata sandi superadmin masih bernilai bawaan	KRITIS	A07 · CWE-798, CWE-521	Terverifikasi (hash)
K-05	Pengaturan situs dapat diubah oleh pengguna mana pun yang login	TINGGI	A01 · CWE-862	Terverifikasi dari kode
K-06	Unggahan SVG pada pengaturan → XSS tersimpan	TINGGI	A03 · CWE-79	Terverifikasi dari kode
K-07	Kata sandi tersimpan secara reversibel dan ditampilkan di HTML	TINGGI	A02 · CWE-257, CWE-312	Terverifikasi dari kode
K-08	Tidak ada pembatas percobaan pada login/registrasi	TINGGI	A07 · CWE-307	Terverifikasi dari kode
K-09	5 kerentanan dependensi (1 kritis, 4 tinggi)	TINGGI	A06 · CWE-1104	composer audit
K-10	Secret JWT SSO tertulis keras di dalam kode	SEDANG	A02 · CWE-798	Terverifikasi dari kode
K-11	Endpoint health check publik membocorkan versi & status basis data	SEDANG	A05 · CWE-200	Terverifikasi dari internet
K-12	Seluruh proxy dipercaya (<code>trustProxies(at: '*')</code>)	SEDANG	A05 · CWE-348	Terverifikasi dari kode
K-13	Pencarian publik menampilkan data pribadi & dapat dipanen otomatis	SEDANG	A01 · CWE-359	Terverifikasi
K-14	Berkas <code>.env.laragon</code> (termasuk APP_KEY dev) ter-commit di Git	RENDAH	A05 · CWE-538	Terverifikasi dari Git

6. Detail Temuan

K-01 KRITIS — Arsip BPKB & Sertifikat Dapat Diunduh Tanpa Autentikasi

Kategori: A01 Broken Access Control · CWE-284 (Improper Access Control), CWE-548 (Exposure of Information Through Directory Listing)

Deskripsi. Dokumen arsip e-LABEL disimpan pada disk `public` (`storage/app/public/elabel/`), yang diakses web server melalui symlink `public/storage`. Berkas pada disk ini dilayani langsung sebagai berkas statis, sehingga **tidak melewati middleware autentikasi apa pun**. Nama berkas dibentuk dari data aset itu sendiri dan berpola konsisten, sehingga daftar URL dapat disusun secara otomatis dari data yang juga tersedia publik.

Lokasi:

- `public/storage` → symlink ke `/home/arif/Projek/SIPAT_Terpadu/storage/app/public`
- `storage/app/public/elabel/` — 718 berkas (bpkb, bpkb_penjualan, sertifikat, surat_penyerahan, bpkb_delete), total 774 berkas / 1,2 GB seluruhnya
- `config/filesystems.php` — disk `public`, root `storage/app/public`
- Penyimpanan berkas: `ElabelBpkbController`, `ElabelSertifikatController`, `ElabelSmartBpkbExtractorController` (`->store(..., 'public')`)

Bukti (uji langsung, tanpa login, 24 September 2026):

```
GET https://terpadu.sipat-donggala.my.id/storage/elabel/bpkb/b1216shx_2011_R405.pdf
→ HTTP 200 · Content-Type: application/pdf · 584.131 byte

GET https://terpadu.sipat-donggala.my.id/storage/elabel/bpkb/dn1b_2025_R409.pdf
→ HTTP 200 · application/pdf · 1.278.245 byte

GET https://terpadu.sipat-donggala.my.id/storage/elabel/sertifikat/09-01-05-03-4-00169_Mess-Mahasiswa-Donggala-Jakarta.pdf
→ HTTP 200 · 2.794.298 byte
```

Pola nama berkas yang memudahkan enumerasi:

Jenis	Pola	Contoh nyata
BPKB	<code>{nomor_rangka}_{tahun}_{id}.pdf</code>	<code>b1216shx_2011_R405.pdf</code>
Sertifikat	<code>{nibar}_{nama-aset}.pdf</code>	<code>09-01-05-03-4-00169_Mess-Mahasiswa-Donggala-Jakarta.pdf</code>

Dampak. Data pribadi dalam skala besar: nama pemegang kendaraan, alamat, NIK, nomor rangka, dan nomor mesin dari 718 dokumen; juga identitas aset tanah milik pemda (termasuk aset yang digunakan ASN seperti Mess Mahasiswa). Risiko lanjutan meliputi

pemalsuan identitas kendaraan, penipuan berbasis data aset, penyalahgunaan dokumen resmi, dan pelanggaran kewajiban perlindungan data pribadi. Karena berkas dapat dienumerasi otomatis, dampaknya tidak terbatas pada kebocoran insidental.

Perbaikan:

1. Pindahkan seluruh dokumen ke disk **privat** (`local`, root `storage/app/private`), bukan `public`. Ubah setiap pemanggilan `store(..., 'public')` dan `Storage::disk('public')` pada modul e-LABEL menjadi disk privat.
2. Layani berkas melalui controller ber-otorisasi yang sudah ada (`viewPdf`, `viewSupportDoc`), dengan tambahan pemeriksaan peran dan kepemilikan OPD.
3. Bila akses langsung tetap diperlukan, gunakan *signed temporary URL* (`Storage::disk('local')->temporaryUrl($path, now()->addMinutes(5))`).
4. Pindahkan berkas lama dan samakan nilai kolom path pada basis data (`pdf_path`, `support_doc_path`, dsb.).
5. Blokir sementara di web server: `location ^~ /storage/elabel/ { deny all; }` sebagai tindakan penghentian darurat sebelum migrasi selesai.
6. Perlakukan seluruh berkas tersebut sebagai **telah bocor**: susun daftar aset terdampak, evaluasi kewajiban pemberitahuan, dan pertimbangkan perubahan penamaan berkas agar tidak lagi memuat data aset.

K-02 KRITIS — Registrasi Akun Terbuka untuk Publik di Produksi

Kategori: A01 Broken Access Control · CWE-287 (Improper Authentication), CWE-1188 (Insecure Default Initialization)

Deskripsi. Rute registrasi bawaan Laravel UI aktif di server produksi dan hanya dilindungi middleware `guest` — tidak ada verifikasi email, tidak ada persetujuan administrator, dan tidak ada pembatasan domain. Akun yang terbentuk langsung memperoleh peran `opd` (nilai default kolom `role`).

Lokasi:

- `routes/web.php:44` — `Auth::routes();`
- `app/Http/Controllers/Auth/RegisterController.php` — middleware hanya `guest`
- `app/Models/User.php` — `MustVerifyEmail` dinonaktifkan (dikomentari)
- `database/migrations/2026_05_15_102006_add_role_and_opd_id_to_users_table.php:15` — `$table->string('role')->default('opd');`

Bukti (uji langsung):

```
GET https://terpadu.sipat-donggala.my.id/register → HTTP 200
```

```
php artisan route:list -v --path=register
```

```
GET|HEAD register Auth\RegisterController@showRegistrationForm 1 web 1 guest
POST register Auth\RegisterController@register 1 web 1 guest
```

Dampak. Siapa pun di internet dapat menjadi pengguna sah aplikasi internal pemerintah daerah tanpa sepengetahuan pengelola. Akun tersebut memperoleh akses ke 167 endpoint ber-middleware `auth`, termasuk seluruh modul arsip e-LABEL (lihat K-03) dan endpoint pengubah pengaturan situs (K-05).

Perbaikan:

```
// routes/web.php
Auth::routes(['register' => false, 'reset' => true]);
```

Bila pendaftaran mandiri memang dibutuhkan, tambahkan kolom `is_active` (default `false`) dan alur persetujuan oleh superadmin; jangan pernah memberikan akses aplikasi sebelum akun disetujui. Hapus juga akun-akun hasil pendaftaran mandiri yang sudah ada pada basis data produksi (perlu pemeriksaan log aktivitas).

K-03 **KRITIS** — Modul e-LABEL Tanpa Pemeriksaan Peran dan Tanpa Pemisahan OPD

Kategori: A01 Broken Access Control · CWE-862 (Missing Authorization), CWE-639 (Authorization Bypass Through User-Controlled Key)

Deskripsi. Berkas `routes/elabel.php` tidak membungkus route dalam grup middleware apa pun; seluruh proteksi bergantung pada deklarasi `middleware()` di masing-masing controller. Semua controller e-LABEL hanya memakai `new Middleware('auth')` **tanpa** pemeriksaan peran. Selain itu, mekanisme pemisahan data per-OPD (`TenantScope`) hanya dipasang pada tiga model — `AsetTanah`, `Vehicle`, dan `EbmdVehicle` — sementara seluruh model e-LABEL (`ElabelBpkb`, `ElabelSertifikat`, `ElabelSuratPenyerahan`, `ElabelBox`, dst.) tidak memilikinya. `ElabelBpkbController@index` pun tidak menyaring kolom `opd_id`.

Lokasi:

- `routes/elabel.php` — seluruh route e-LABEL, tanpa grup middleware
- `app/Http/Controllers/Elabel/*.php` — `middleware()` hanya `auth`
- `app/Models/Scopes/TenantScope.php` — hanya dipakai 3 model
- `app/Http/Controllers/Elabel/ElabelBpkbController.php:39` — `index()` tanpa filter OPD

Bukti. Hasil pemetaan `route:list --json`: **65 endpoint pengubah data hanya memerlukan status login**. Cuplikan yang paling berdampak:

```
POST elabel/bpkb/{id}/update      POST elabel/bpkb/{id}/delete
POST elabel/bpkb                  DELETE elabel/sertifikat/{id}
POST elabel/bpkb/import           PUT elabel/surat-penyerahan/{id}
POST elabel/peminjaman/{id}/approve DELETE elabel/peminjaman/{id}
POST elabel/dynamic/loans/{id}/approve POST settings
DELETE elabel/boxes/{id}          POST elabel/boxes/{id}/merge
```

Dampak. Setiap pengguna yang berhasil login — termasuk akun yang dibuat sendiri melalui K-02 — dapat: membaca seluruh arsip BPKB dan sertifikat **dari semua OPD** (termasuk mengunduh berkas PDF-nya melalui `viewPdf`), mengubah dan menghapus catatan arsip, menyetujui atau menolak peminjaman arsip, serta menggabungkan/memecah box penyimpanan. Kerusakan pada catatan arsip aset daerah berdampak langsung pada laporan BMD dan audit internal.

Perbaikan:

1. Bungkus seluruh route pada `routes/elabel.php`: `Route::middleware(['auth'])->group(function () { ... });` sebagai jaring pengaman.
2. Tambahkan `new Middleware('role:superadmin,admin')` pada semua aksi mutasi (store, update, delete, import, approve, reject, restore, merge, split, cleanup).
3. Pasang `TenantScope` pada model e-LABEL, dengan fallback gagal-tertutup (fail-safe) seperti yang sudah benar diterapkan di `TenantScope` saat ini; model perlu kolom `opd_id` yang konsisten.
4. Tambahkan Policy per-model untuk aksi tulis, dan unit test otorisasi (mis. pengguna `opd` harus menerima 403 pada `elabel/bpkb/{id}/delete`).

K-04 KRITIS — Kata Sandi Superadmin Masih Bernilai Bawaan

Kategori: A07 Identification and Authentication Failures · CWE-798 (Use of Hard-coded Credentials), CWE-521 (Weak Password Requirements)

Deskripsi. Akun superadmin bawaan (`admin@example.com`, `users.id = 1`) di-seed dengan kata sandi `admin123`. Nilai ini masih tercatat pada berkas seeder dan pada migrasi yang mengisi kolom `plain_password`. Verifikasi dilakukan secara **offline** terhadap hash bcrypt pada dump basis data — tidak ada percobaan login ke server produksi.

Lokasi:

- `database/seeder/DatabaseSeeder.php:32` — `Hash::make('admin123')`
- `database/migrations/2026_09_03_000001_add_plain_password_to_users_table.php:25` — `Crypt::encryptString('admin123')`
- Dump `mysql-db_sipat_terpadu.sql`, baris `users` id 1

Bukti (verifikasi hash, offline):

```
Hash : $2y$12$rvce3boubFcP0mor2CfcV0qBYCVJqCEr1fMjKC4jYYMg0KSxLewo6
Uji   : password_verify("admin123", hash) → true
       : password_verify("password", ...) → false
       : password_verify("admin1234", ...) → false
```

Dampak. Digabungkan dengan K-08 (tanpa pembatas percobaan login pada `/login`) dan K-02 (registrasi terbuka sebagai jalur masuk alternatif), akun superadmin dapat dikuasai. Akun ini berwenang penuh: manajemen pengguna, reset kata sandi seluruh pengguna, unduh/hapus backup basis data (berisi `.env`, seluruh hash sandi, dan data aset), serta

penghapusan data master. Pengambilalihan akun superadmin berarti penguasaan penuh atas aplikasi dan basis datanya.

Perbaikan:

1. Ganti kata sandi superadmin **segera** dengan nilai acak kuat (`Str::password(20)`), dan aktifkan kembali verifikasi email untuk akun admin.
 2. Hapus kata sandi bawaan dari seeder dan migrasi; jangan pernah menyertakan kredensial di dalam kode yang di-commit.
 3. Hapus baris `plain_password` yang menyimpan nilai tersebut.
 4. Audit log aktivitas untuk mendeteksi login superadmin yang tidak dikenal, khususnya sejak audit sebelumnya (22 Agustus 2026).
-

K-05 **TINGGI** — Pengaturan Situs Dapat Diubah oleh Pengguna Mana Pun yang Login

Kategori: A01 Broken Access Control · CWE-862

Deskripsi. `SettingController` (pengelola identitas situs: nama, subjudul, logo, gambar hero) hanya dilindungi middleware `auth`. Tidak ada pemeriksaan peran, padahal `MasterDataController` dan pengaturan lain di aplikasi yang sama sudah memakai `role:superadmin,admin`.

Lokasi: `app/Http/Controllers/Admin/SettingController.php` — `middleware()` mengembalikan `[ new Middleware('auth') ]`. Route terkait: `POST settings (routes/web.php)`, `POST settings/admin-template`.

Dampak. Defacement halaman publik pemerintah daerah — penggantian nama, logo, dan gambar beranda yang tampil kepada masyarakat; dapat digunakan untuk kampanye disinformasi atau pengelabuan (mis. memasang logo/narahubung palsu). Setiap pengguna berakun dapat melakukannya.

Perbaikan. Ubah menjadi `new Middleware('role:superadmin,admin')`, dan untuk perubahan identitas visual sebaiknya dibatasi `role:superadmin`. Tambahkan pencatatan aktivitas (audit log) pada setiap perubahan pengaturan.

K-06 **TINGGI** — Unggahan SVG pada Pengaturan Menyebabkan XSS Tersimpan

Kategori: A03 Injection · CWE-79 (Improper Neutralization of Input During Web Page Generation)

Deskripsi. Berkas gambar pengaturan divalidasi dengan `mimes:jpeg,png,jpg,webp,svg`. SVG adalah dokumen berbasis XML yang dapat memuat skrip. Berkas disimpan pada `public/uploads/settings` dan disajikan dari origin yang sama dengan aplikasi, sehingga skrip di dalamnya dijalankan dengan konteks origin aplikasi.

Lokasi:

- `app/Http/Requests/Admin/UpdateSettingRequest.php` — aturan `['nullable', 'image', 'mimes:jpeg,png,jpg,webp,svg', 'max:5120']`
- `app/Http/Controllers/Admin/SettingController.php` — penyimpanan ke `public_path('uploads/settings')`

Dampak. Digabungkan dengan K-05 (siapa pun yang login dapat mengunggah), penyerang dapat menempatkan skrip yang berjalan pada peramban setiap pengunjung halaman publik, **termasuk superadmin**. Skrip tersebut dapat mencuri sesi, melakukan aksi atas nama korban (reset kata sandi pengguna lain, mengunduh backup basis data), atau memodifikasi tampilan situs.

Perbaikan.

1. Hapus `svg` dari daftar tipe yang diizinkan.
2. Bila SVG memang dibutuhkan, lakukan sanitasi (mis. `enshrined/svg-sanitize`) sebelum disimpan.
3. Tambahkan header `Content-Security-Policy` dan sajikan berkas unggahan dengan `X-Content-Type-Options: nosniff`.

K-07 TINGGI — Kata Sandi Tersimpan Secara Reversibel dan Ditampilkan di HTML

Kategori: A02 Cryptographic Failures · CWE-257 (Storing Passwords in a Recoverable Format), CWE-312 (Cleartext Storage of Sensitive Information)

Deskripsi. Selain hash bcrypt yang benar, tabel `users` memiliki kolom `plain_password` yang di-cast `encrypted` — artinya kata sandi asli dapat didekripsi kembali oleh aplikasi. Nilai ini bahkan dikirim ke peramban admin pada halaman manajemen pengguna. Kata sandi OPD yang dibuat otomatis juga berpola `DGL-` diikuti 4 karakter (≈ 14 juta kombinasi), jauh di bawah kaidah yang lazim.

Lokasi:

- `app/Models/User.php:88` — `'plain_password' => 'encrypted'` (dan `$fillable`)
- `app/Services/AccountService.php:43` — `'plain_password' => $rawPassword`
- `app/Http/Controllers/Admin/UserController.php:80, 110, 190`
- `resources/views/users/index.blade.php:155` — `data-password="{{ $user->plain_password ?? '' }}"`
- `database/migrations/2026_09_03_000001_add_plain_password_to_users_table.php`

Dampak. Kebocoran `APP_KEY` (misalnya melalui berkas backup yang memuat `APP_KEY` bersama dump basis data) membuat **seluruh kata sandi pengguna terbaca seketika**, tanpa perlu memecahkan hash. Nilai `plain_password` juga harus dianggap telah terekspos di sisi peramban dan log.

Perbaikan. Hapus kolom `plain_password` beserta tampilan dan pengisiannya; ganti dengan alur "reset kata sandi" (kirim token satu kali pakai). Perpanjang kata sandi yang dibangkitkan (`Str::password(16)`). Rotasi `APP_KEY` setelah pembersihan, dengan memperhatikan data lain yang terenkripsi olehnya (`teams`/backup terenkripsi).

K-08 **TINGGI** — Tidak Ada Pembatas Percobaan pada Login dan Registrasi

Kategori: A07 Identification and Authentication Failures · CWE-307 (Improper Restriction of Excessive Authentication Attempts)

Deskripsi. Rute `login` dan `register` tidak memiliki middleware `throttle`. Satu-satunya pembatasan di seluruh aplikasi terdapat pada `VerificationController` (`throttle:6,1`). Login Laravel UI tidak menyediakan pembatasan secara bawaan.

Lokasi: `app/Http/Controllers/Auth/LoginController.php` — `middleware()` hanya `guest` / `auth`; `routes/web.php` — `Auth::routes()`.

Bukti:

```
php artisan route:list -v --path=login
POST login Auth\LoginController@login  web  guest  ← tanpa throttle
```

Dampak. Percobaan kata sandi dapat dilakukan tanpa batas. Digabungkan dengan pola kata sandi akun OPD (`DGL-XXXX`) dan ketersediaan alamat email akun yang berpola (`admin.<opd>@e-randis.id`), kekuatan akun OPD menjadi jauh lebih lemah daripada yang tampak.

Perbaikan.

```
// LoginController::middleware()
return [
    new Middleware('guest', except: ['logout']),
    new Middleware('auth', only: ['logout']),
    new Middleware('throttle:5,1', only: ['login']),
];
```

Tambahkan juga pembatasan berdasarkan kombinasi email + IP (`RateLimiter`), serta `throttle:3,1` pada registrasi. Pertimbangkan autentikasi dua faktor untuk akun superadmin.

K-09 **TINGGI** — Lima Kerentanan pada Dependensi

Kategori: A06 Vulnerable and Outdated Components · CWE-1104

Deskripsi. `composer audit` melaporkan 5 advisori yang memengaruhi 2 paket. Aplikasi memproses berkas XLSX/CSV yang diunggah pengguna (impor kendaraan, e-LABEL,

bangunan, rekonsiliasi e-BMD), sehingga kerentanan pada pustaka pembaca spreadsheet bersifat relevan dan bukan teoretis.

Paket	Tingkat	CVE	Ringkasan	Versi terdampak
phpoffice/phpspreadsheet	CRITICAL	CVE-2026-45034	Bypass patch CVE-2026-34084	≤ 1.30.4
phpoffice/phpspreadsheet	HIGH	CVE-2026-59933	Self-loop sektor OLE → kehabisan memori	≤ 1.30.5, 2.x ≤ 2.1.17, 2.2-2.4.6, 3.3-3.10.6, 4.0-5.8.0
phpoffice/phpspreadsheet	HIGH	CVE-2026-59932	Ekspansi gzip Gnumeric tanpa batas → kehabisan memori	idem
phpoffice/phpspreadsheet	HIGH	CVE-2026-59931	Bypass SSRF lewat redirect HTTP pada WEBSERVICE()	idem
maatwebsite/excel	HIGH	CVE-2026-84374	Penulisan ekspor di luar disk bila path dikendalikan pemanggil	≥ 3.1.8, < 3.1.70

Dampak. Dua kerentanan kehabisan memori dapat dijadikan serangan penolakan layanan hanya dengan satu berkas unggahan yang disusun khusus; kerentanan `maatwebsite/excel` berpotensi menulis berkas di luar direktori yang dimaksud bila ada endpoint ekspor yang menerima path dari pemanggil (perlu ditelusuri lebih lanjut pada kode ekspor).

Perbaikan.

```
composer update maatwebsite/excel phpspreadsheet --with-dependencies
# pastikan maatwebsite/excel >= 3.1.70 dan phpspreadsheet pada versi yang ditambah
```

Jalankan `composer audit` pada pipeline CI, batasi ukuran unggahan, dan pertimbangkan pemrosesan impor melalui antrean agar tidak membebani proses web.

K-10 **SEDANG** — Secret JWT SSO Tertulis Keras di Dalam Kode

Kategori: A02 Cryptographic Failures · CWE-798

Deskripsi. Middleware `SsoAuthenticate` memverifikasi token SSO memakai kunci HMAC yang ditulis langsung di dalam kode sumber. Middleware ini ter-alias (`'sso'`) pada `bootstrap/app.php`, tetapi **tidak dipakai pada route mana pun** saat ini — sehingga belum dapat dieksploitasi. Namun nilainya berada di dalam repositori, dan setelah lolos

verifikasi middleware tersebut membuat pengguna baru melalui `firstOrCreate` dengan peran yang diambil dari klaim token, tanpa verifikasi kata sandi.

Lokasi: `app/Http/Middleware/SsoAuthenticate.php` — `$secretKey` = `'SIPAT_SSO_SECRET_KEY_JWT_2026_SECURE_TOKEN_DONGGALA';` (alias terdaftar di `bootstrap/app.php:30`).

Dampak. Bila aplikasi SSO pada `auth.sipat-donggala.my.id` memakai kunci yang sama (lazim pada sistem yang dikembangkan bersama), siapa pun yang pernah melihat repositori ini dapat **memalsukan token** dan masuk sebagai superadmin. Karena middleware belum terpasang, risiko saat ini bersifat laten — namun kuncinya sudah bocor dan tetap harus dirotasi.

Perbaikan. Pindahkan kunci ke `.env` (`SSO_JWT_SECRET`), **rotasi kuncinya di kedua sisi**, hapus middleware bila tidak dipakai, dan bila akan dipakai: verifikasi penerbit/audiens token, jangan memetakan peran langsung dari klaim tanpa pemetaan yang dikendalikan server, serta catat setiap pembuatan akun otomatis ke audit log.

K-11 **SEDANG** — Endpoint Health Check Publik Membocorkan Versi dan Status Basis Data

Kategori: A05 Security Misconfiguration · CWE-200 (Exposure of Sensitive Information)

Deskripsi. `/api/health-check` dapat diakses tanpa autentikasi dan mengembalikan versi framework serta status koneksi basis data. Ketika basis data bermasalah, pesan exception dikembalikan apa adanya.

Lokasi: `app/Http/Controllers/HealthCheckController.php` — `'framework' => 'Laravel '`. `app()->version()`, `'database' => $dbStatus` dengan penyertaan `$e->getMessage()`.

Bukti:

```
GET https://terpadu.sipat-donggala.my.id/api/health-check
{"project":"E-RANDIS","framework":"Laravel 12.67.0","status":"healthy",
  "database":"connected","timestamp":"2026-09-24 14:14:37"}
```

Dampak. Pemetaan versi presisi memudahkan penyerang memilih exploit yang sesuai (versi ini bahkan sesuai dengan kerentanan dependensi pada K-09); pesan error basis data dapat mengungkap host/nama basis data.

Perbaikan. Kembalikan hanya `{"status":"ok"}` tanpa versi, tanpa status internal, dan tanpa pesan exception; batasi akses ke jaringan internal atau lindungi dengan token pemantauan.

K-12 **SEDANG** — Seluruh Proxy Dipercaya

Kategori: A05 Security Misconfiguration · CWE-348 (Use of Less Trusted Source)

Deskripsi. `bootstrap/app.php` memakai `$middleware->trustProxies(at: '*')`, sehingga header `X-Forwarded-For` dari sumber mana pun dipercaya. Aplikasi akan mencatat IP palsu pada audit log, dan pembatasan berbasis IP (termasuk throttle yang disarankan pada K-08) dapat dilewati.

Perbaikan. Ganti `'*'` dengan alamat IP atau rentang CIDR reverse proxy yang benar-benar dipakai.

K-13 **SEDANG** — Pencarian Publik Menampilkan Data Pribadi dan Dapat Dipanen Otomatis

Kategori: A01 Broken Access Control · CWE-359 (Exposure of Private Personal Information)

Deskripsi. Pencarian publik mengembalikan nama pemegang kendaraan (`pemegang`), nomor polisi, nomor register, dan foto kendaraan. Endpoint ini tidak memiliki pembatas laju dan membatasi 30 hasil per permintaan, sehingga seluruh 1.038 kendaraan dapat dipanen dengan sekitar 35 permintaan otomatis. Statistik agregat portal (`/api/public/stats`) juga terbuka tanpa pembatasan.

Lokasi: `app/Services/UnifiedAssetSearchService.php` (`searchVehicles`, `getPortalStats`, `getFilterOptions`); `routes/web.php` — `/search/*` dan `/api/public/*` tanpa `throttle`.

Perbaikan. Hapus atau samarkan `pemegang` untuk akses publik (tampilkan hanya setelah login), tambahkan `throttle:30,1` pada endpoint pencarian dan statistik, serta pertimbangkan CAPTCHA untuk pola permintaan berulang.

K-14 **RENDAH** — Berkas `.env.laragon` Ter-commit di Git

Kategori: A05 Security Misconfiguration · CWE-538 (Insertion of Sensitive Information into Excluded File)

Deskripsi. `.env.laragon` ikut tersimpan dalam repositori dan memuat `APP_KEY=base64:nzI5W347b4p7YrwTxv5CsL1r+Vs+CNbGZ+q4roCoZm4=` serta kredensial basis data lokal (root tanpa kata sandi). Konfigurasi ini untuk lingkungan pengembangan, bukan produksi, sehingga risikonya rendah — namun menunjukkan kebiasaan yang berbahaya bila diterapkan pada `.env` produksi.

Perbaikan. `git rm --cached .env.laragon`, tambahkan polanya ke `.gitignore`, dan pastikan `.env` produksi tidak pernah masuk repositori (saat ini sudah benar).

7. Rantai Serangan Gabungan (Skenario Paling Realistis)

Temuan di atas tidak berdiri sendiri. Rangkaian yang paling mungkin dijalankan penyerang, dari luar tanpa kredensial:

Skenario A — Pengambilalihan akun superadmin (jalur terpendek). Penyerang menemukan halaman `/register` (K-02) atau langsung halaman `/login`. Tanpa pembatas percobaan (K-08), ia mencoba kata sandi lazim pada `admin@example.com` — `admin123` (K-04) berhasil. Ia memperoleh hak superadmin tanpa pernah menyentuh temuan lain.

Skenario B — Pemanenan arsip tanpa akun sama sekali. Penyerang tidak memerlukan akun. Ia mengumpulkan nomor rangka/NIBAR dari pencarian publik (K-13), membentuk nama berkas sesuai pola, dan mengunduh 718 dokumen PDF berisi data pribadi (K-01) — seluruhnya melalui permintaan HTTP biasa yang tidak terautentikasi.

Skenario C — Kerusakan data arsip atas nama OPD. Penyerang membuat akun (K-02), lalu membaca dan menghapus catatan arsip BPKB/sertifikat seluruh OPD karena modul e-LABEL tidak memeriksa peran maupun kepemilikan data (K-03). Jejak tindakannya juga dapat dikaburkan dengan memalsukan IP melalui `X-Forwarded-For` (K-12). Secara paralel ia mengubah nama/logo situs (K-05) dan menanam skrip pada unggahan SVG (K-06) agar menyerang superadmin.

Setiap skenario di atas hanya memerlukan satu atau dua temuan. Artinya, memperbaiki sebagian saja tidak menutup jalan masuk.

8. Rekomendasi dan Urutan Penanganan

Tahap 1 — Penghentian darurat (≤ 24 jam)

No	Tindakan	Temuan
1	Ganti kata sandi superadmin; hapus <code>admin123</code> dari seeder dan migrasi	K-04
2	Nonaktifkan registrasi: <code>Auth::routes(['register' => false])</code>	K-02
3	Blokir <code>/storage/elabel/</code> di web server, lalu pindahkan berkas ke disk privat	K-01
4	Tambahkan <code>throttle:5,1</code> pada login dan <code>throttle:3,1</code> pada registrasi	K-08
5	Periksa audit log untuk login/pembuatan akun yang tidak dikenal sejak 22 Agustus 2026	K-02, K-03, K-04

Tahap 2 — Minggu ini

No	Tindakan	Temuan
6	<code>composer update maatwebsite/excel phpooffice/phpspreadsheet</code> ; jalankan <code>composer audit</code> di CI	K-09
7	Batasi endpoint mutasi e-LABEL dan pengaturan situs ke <code>role:superadmin,admin</code>	K-03, K-05
8	Pasang <code>TenantScope</code> pada seluruh model e-LABEL	K-03
9	Hapus kolom <code>plain_password</code> , tampilan, dan pengisiannya	K-07
10	Hapus <code>svg</code> dari daftar tipe unggahan pengaturan	K-06
11	Tambahkan unit test otorisasi (pengguna <code>opd</code> → 403 pada aksi admin)	K-02, K-03

Tahap 3 — Bulan ini

No	Tindakan	Temuan
12	Pindahkan secret SSO ke <code>.env</code> dan rotasi kuncinya	K-10
13	Sederhanakan respons health check	K-11
14	Ganti <code>trustProxies(at: '*')</code> dengan IP proxy yang sebenarnya	K-12
15	Tambahkan <code>throttle</code> pada pencarian publik; samarkan nama pemegang	K-13
16	Bersihkan <code>.env.laragon</code> dari Git dan perbarui <code>.gitignore</code>	K-14
17	Susun daftar aset terdampak dan evaluasi kewajiban perlindungan data pribadi	K-01
18	Pertimbangkan autentikasi dua faktor untuk akun superadmin & admin	K-04, K-08

Daftar periksa validasi

- [] Registrasi tidak dapat diakses publik (POST `/register` → 404/403)
 - [] `https://.../storage/elabel/bpkb/<berkas>` → 403/404 tanpa login
 - [] Endpoint `POST elabel/*`, `DELETE elabel/*`, `POST settings` → 403 untuk peran `opd`
 - [] Pengguna `opd` hanya melihat data OPD-nya sendiri (uji lintas OPD)
 - [] `composer audit` bersih
 - [] `php artisan route:list -v --path=login` menampilkan `throttle`
 - [] Kolom `plain_password` sudah tidak ada
 - [] Kata sandi superadmin bukan nilai bawaan
-

9. Kontrol yang Sudah Baik (Kekuatan Aplikasi)

Penting dicatat agar perbaikan tidak mengganggu bagian yang sudah benar:

- Middleware `role` (`CheckRole`) bekerja dengan tepat: superadmin memiliki akses penuh, perbandingan dilakukan terhadap enum, dan pengguna tanpa hak diarahkan kembali dengan pesan kesalahan. Modul Master Data, Manajemen User, Audit Log, dan Backup sudah terlindungi dengan benar (`role:superadmin` / `role:superadmin,admin`).
 - `TenantScope` benar secara desain — termasuk *fail-safe* yang mengunci akses (`whereRaw('1 = 0')`) bila `opd_id` / `sub_opd_id` kosong. Masalahnya hanya cakupan penerapannya, bukan logikanya.
 - Kata sandi akun disimpan sebagai hash bcrypt dengan `BCRYPT_ROUNDS=12`.
 - `APP_DEBUG=false` pada produksi — jejak kesalahan tidak tampil ke publik.
 - `.env` produksi tidak dapat diakses (HTTP 403) dan dump SQL di direktori proyek tidak terekspos (HTTP 404).
 - Berkas backup tersimpan di `storage/app/backups` (privat), dan endpoint unduh/hapus backup sudah dibatasi `role:superadmin`.
 - Query memakai Eloquent/parameter binding; tidak ditemukan SQL injection pada jalur yang menerima masukan pengguna (`whereRaw` yang ada memakai placeholder).
 - Mass assignment terkendali melalui `$fillable` (satu model, `OpdSipat`, tidak memakainya — perlu diperiksa namun tidak berisiko langsung).
-

10. Lampiran

Lampiran A — Perintah verifikasi temuan

```
# K-01 arsip publik (tanpa kredensial)
curl -s -o /dev/null -w "%{http_code} %{content_type}\n" \
  https://terpadu.sipat-donggala.my.id/storage/elabel/bpkb/b1216shx_2011_R405.pdf

# K-02 registrasi terbuka
curl -s -o /dev/null -w "%{http_code}\n" https://terpadu.sipat-donggala.my.id/register
php artisan route:list -v --path=register

# K-03 otorisasi: daftar route tulis yang hanya butuh login
php artisan route:list --json | python3 -c "
import json,sys
d=json.load(sys.stdin)
for r in d:
    mw=r.get('middleware') or []
    v=r['method'].split('|')[0]
    if 'auth' in mw and v in {'POST','PUT','PATCH','DELETE'} and not
any(m.startswith('role:') for m in mw):
        print(v, r['uri'])
"

# K-04 verifikasi kata sandi bawaan (offline, terhadap hash pada dump)
php -r 'var_dump(password_verify("admin123",
"\$2y\$12\$rvce3boubFcP0mor2CfcV0qBYCVJqCER1fMjKC4jYYMg0KSxLewo6"))';

# K-08 pembatas percobaan login
php artisan route:list -v --path=login

# K-09 dependensi
composer audit --no-interaction

# K-11 health check
curl -s https://terpadu.sipat-donggala.my.id/api/health-check

# K-14 berkas lingkungan di Git
git ls-files | grep -E "^\.env"
```

Lampiran B — Rekapitulasi berkas terdampak K-01

Direktori	Jumlah berkas
storage/app/public/elabel/	718
storage/app/public/mpdf_temp/	47
storage/app/public/vehicles/	3
storage/app/public/kop/	3
storage/app/public/dynamic/, avatars/	2
Total pada disk publik	774 (1,2 GB)

Subdirektori elabel/ : bpkb/, bpkb_penjualan/, bpkb_delete/, bpkb-deletes/, sertifikat/, surat_penyerahan/, profile_photos/.

Lampiran C — Keterkaitan dengan kewajiban pengelolaan

Aspek	Keterkaitan
UU No. 27/2022 (Pelindungan Data Pribadi)	K-01, K-07, K-13 menyangkut data pribadi (nama pemegang, NIK, alamat). Perlu penilaian kewajiban pemberitahuan bila terbukti diakses pihak tak berhak.
SPBE / keamanan informasi instansi	K-02, K-03, K-04, K-05 menyangkut pengendalian akses dan manajemen kredensial yang menjadi syarat dasar pengamanan aplikasi layanan publik.
Audit internal BMD	K-03 berpotensi merusak integritas catatan arsip aset sehingga memengaruhi laporan barang milik daerah.
Audit sebelumnya (audit.md , 22 Agu 2026)	Perlu dikoreksi: pernyataan "seluruh temuan selesai" tidak didukung bukti pengujian otorisasi, paparan berkas, dan jalur registrasi.

Lampiran D — Pernyataan batasan pengujian

- Pengujian terhadap server produksi dibatasi pada permintaan GET/HEAD non-destruktif ke 9 URL. Tidak ada upaya autentikasi, pembuatan akun, penghapusan, atau perubahan data.
 - Verifikasi kata sandi bawaan dilakukan sepenuhnya **offline** terhadap hash pada berkas dump basis data; tidak ada percobaan login ke sistem produksi.
 - Temuan K-02 dan K-03 diverifikasi melalui pembacaan kode dan pemetaan route. Pembuktian dengan akun uji pada produksi belum dilakukan.
 - Laporan ini memuat detail teknis yang belum ditutup dan sebaiknya tidak disebarluaskan di luar pihak yang berwenang melakukan perbaikan.
-

Akhir laporan.

Disusun: 24 September 2026 · Berdasarkan pemeriksaan kode pada `/home/arif/Projek/SIPAT_Terpadu` (commit `7c06af2`) dan uji HTTP non-destruktif terhadap `https://terpadu.sipat-donggala.my.id`.